PROPUESTA DE SOLUCIÓN TÉCNICA · ARQUITECTURA DBA

Plan de Solución Técnica: Arquitectura de Respaldos, Seguridad y DRP

Plan integral de mitigación para el módulo de administración y respaldos de Mundo Escolar S.A.: resolución del control de accesos sin privilegios globales, aprovisionamiento automatizado del filesystem, protocolo DRP fuera de banda y orquestación multiplataforma.

SISTEMA Y PROYECTO
Mundo Escolar S.A. — Módulo de Mantenimiento DBA y Continuidad de Negocio

ORIGEN DE REQUERIMIENTOS
Análisis Técnico y Observaciones de Auditoría DBA (Samir)

AUTOR DE LA SOLUCIÓN
Mauricio Chavarría Pérez (Liderazgo Técnico)

FECHA DE PRESENTACIÓN
31 de Octubre de 2026

ESTÁNDARES DE REFERENCIA
NIST SP 800-34 (DRP), CIS SQL Server Benchmark, OWASP ASVS v4.0

ESTADO DE LA PROPUESTA
Lista para Despliegue y Aprobación del Equipo

PoLP	0 Riesgo DoS	Multi-Edición	Regla 3-2-1
MENOR PRIVILEGIO (SIN 'SA')	DRP FUERA DE BANDA	EXPRESS & ENTERPRISE OK	COPIA OFF-SITE SEGURA

RESUMEN EJECUTIVO DE LA SOLUCIÓN PROPUESTA

El presente documento proporciona las **soluciones técnicas de ingeniería definitivas** a los puntos comentados por Samir. Se subsana la brecha de autorización en el login de aplicación mediante encapsulamiento criptográfico con `WITH EXECUTE AS OWNER` (evitando el uso inseguro de la cuenta `sa`), se estandariza el aprovisionamiento de permisos sobre la carpeta del servidor mediante PowerShell, se formaliza el procedimiento de recuperación ante desastres (DRP) fuera de banda y se ofrece una estrategia de automatización portable para entornos con SQL Server Express o Enterprise.

1. Solución al Control de Accesos: Principio de Menor Privilegio (PoLP)

Samir identificó correctamente que el login de aplicación `login_mundo_app` recibe únicamente el permiso `EXECUTE ON SCHEMA::dbo`, el cual resulta insuficiente en SQL Server cuando un procedimiento ejecuta `BACKUP DATABASE` mediante SQL dinámico (`EXEC sp_executesql`).

1.1. Evaluación de Alternativas de Mitigación

Frente a este problema, existen tres enfoques posibles con implicaciones radicales de seguridad:

ENFOQUE TÉCNICO	MECANISMO	RIESGO DE SEGURIDAD	VEREDICTO
Enfoque A: Uso de cuenta 'sa'	Conectar el backend NestJS con credenciales de `sa`.	**Riesgo Crítico:** Acceso irrestricto a todo el servidor; cualquier inyección SQL permite tomar control total del host.	**Rechazado**
Enfoque B: Rol `db_backupoperator`	Hacer a `usr_mundo_app` miembro del rol fijo de respaldo.	**Riesgo Medio:** El backend puede volcar cualquier tabla a disco por SQL arbitrario, habilitando exfiltración de datos.	**Aceptable**
Enfoque C: Encapsulamiento `EXECUTE AS OWNER`	Firmar el SP para que eleve contexto sólo durante el backup.	**Riesgo Nulo:** El usuario sólo puede ejecutar el SP controlado. Respeta el Principio de Menor Privilegio (PoLP).	**RECOMENDADO**

1.2. Implementación de la Solución Recomendada (Enfoque C)

Se actualizan las firmas de los cuatro procedimientos de administración en `sql/01_despliegue_secuencial/10_CrearProcedimientos.sql` agregando la cláusula `WITH EXECUTE AS OWNER`:

```
-- Modificación de SP_DBA_EjecutarBackupCompleto
CREATE OR ALTER PROCEDURE dbo.SP_DBA_EjecutarBackupCompleto
    @RutaCarpetaBackup VARCHAR(255) = 'C:\SQLBackup'
WITH EXECUTE AS OWNER -- Ejecuta con privilegios de dbo (creador del objeto)
AS
BEGIN
    SET NOCOUNT ON;
    BEGIN TRY
        DECLARE @FechaStr VARCHAR(20) = REPLACE(REPLACE(REPLACE(CONVERT(VARCHAR(19), GETDATE(), 120), '-', ''), ':', ''), ' ',
'_');
        DECLARE @ArchivoBak VARCHAR(500) = @RutaCarpetaBackup + '\MUNDO_ESCOLAR_FULL_' + @FechaStr + '.bak';

        DECLARE @Sql NVARCHAR(MAX) = N'BACKUP DATABASE MUNDO_ESCOLAR TO DISK = ''' + @ArchivoBak + ''' WITH FORMAT, INIT, COMPRES
SION, STATS = 10;';
        EXEC sp_executesql @Sql;

        INSERT INTO Bitacora (Id_Usuario, Accion, Tabla_Afectada, Fecha_Hora, Descripcion)
        VALUES (1, 'BACKUP_FULL', 'DATABASE', GETDATE(), CONCAT('Respaldo completo generado en: ', @ArchivoBak));

        SELECT 'Respaldo completo generado exitosamente.' AS Mensaje, @ArchivoBak AS Archivo;
    END TRY
    BEGIN CATCH
        INSERT INTO Bitacora (Id_Usuario, Accion, Tabla_Afectada, Fecha_Hora, Descripcion)
        VALUES (1, 'ERROR_BACKUP_FULL', 'DATABASE', GETDATE(), CONCAT('Fallo en backup completo: ', ERROR_MESSAGE()));
        THROW;
    END CATCH
END;
GO
```

Procedimientos homologados con la misma directiva:

- `dbo.SP_DBA_EjecutarBackupDiferencial`
- `dbo.SP_DBA_EjecutarBackupLog`
- `dbo.SP_DBA_VerificarIntegridadBackup`

> **Beneficio Arquitectónico:** El backend NestJS mantiene únicamente permisos `EXECUTE` ordinarios. Si la aplicación web es vulnerada, el atacante no puede ejecutar comandos `BACKUP` arbitrarios en la consola de SQL Server.

2. Solución al Aprovisionamiento del Filesystem y Rutas Parametrizadas

Para evitar que el usuario deba configurar manualmente permisos complejos de Windows o que ocurra el error de sistema operativo `Operating system error 5 (Access is denied)`, se proporciona una solución automatizada en dos niveles:

2.1. Script de Automatización PowerShell para Permisos de Windows (Host de BD)

Se crea el script de infraestructura `sql/03_administracion_mantenimiento/Preparar_Carpeta_Respaldos.ps1`. Este script detecta automáticamente el nombre de la instancia local de SQL Server, obtiene la cuenta de servicio exacta (Service SID) y le asigna privilegios de control total en el sistema de archivos:

```
# sql/03_administracion_mantenimiento/Preparar_Carpeta_Respaldos.ps1
param(
    [string]$RutaBackup = "C:\SQLBackup"
)

Write-Host "=== APROVISIONAMIENTO SEGURO DE CARPETA DE RESPALDOS ===" -ForegroundColor Cyan

# 1. Crear la carpeta si no existe
if (-not (Test-Path $RutaBackup)) {
    New-Item -ItemType Directory -Path $RutaBackup -Force | Out-Null
    Write-Host "Carpeta creada exitosamente: $RutaBackup" -ForegroundColor Green
} else {
    Write-Host "La carpeta ya existe: $RutaBackup" -ForegroundColor Yellow
}

# 2. Identificar el nombre de la cuenta de servicio de SQL Server
$serviceAccount = (Get-WmiObject Win32_Service | Where-Object { $_.Name -match "MSSQL.*" -and $_.State -eq "Running" } | Select-O
bject -First 1).StartName

if (-not $serviceAccount) {
    # Fallback para instancia predeterminada o Express
    $serviceAccount = "NT SERVICE\MSSQLSERVER"
}

Write-Host "Cuenta de servicio de SQL Server detectada: $serviceAccount" -ForegroundColor Cyan

# 3. Conceder permisos de lectura, escritura y modificacion (ACL)
$acl = Get-Acl $RutaBackup
$rule = New-Object System.Security.AccessControl.FileSystemAccessRule($serviceAccount, "FullControl", "ContainerInherit,ObjectInh
erit", "None", "Allow")
$acl.SetAccessRule($rule)
Set-Acl $RutaBackup $acl

Write-Host "Permisos FullControl aplicados con éxito a '$serviceAccount' sobre '$RutaBackup'." -ForegroundColor Green
```

2.2. Manejo de Rutas Parametrizadas en el Backend (Desacoplamiento de C:\SQLBackup)

Para que la ruta de respaldo no esté atada a `C:SQLBackup`, el backend de NestJS ya se encuentra preparado mediante el DTO `EjecutarBackupDto`:

```
// backend/src/dba/dto/dba.dto.ts
export class EjecutarBackupDto {
  @ApiPropertyOptional({
    description: 'Ruta física en el servidor donde se escribirá el archivo .bak/.trn',
    default: 'C:\SQLBackup',
    example: 'D:\Respaldos\MundoEscolar'
  })
  @IsOptional()
  @IsString()
  rutaCarpeta?: string;
}
```

Esto permite que si la base de datos se despliega en un entorno empresarial con partición dedicada (por ejemplo, unidad `E:DataBackups` o volumen NFS), la aplicación consuma la ruta configurada en la variable de entorno `BACKUP_STORAGE_PATH` del archivo `.env` sin tocar una sola línea de código SQL.

3. Protocolo Seguro de Recuperación ante Desastres (DRP) Fuera de Banda

En respuesta a la inquietud sobre la restauración, establecemos formalmente que **la restauración de bases de datos productivas es por diseño un procedimiento Fuera de Banda (Out-of-Band)**. A continuación se presenta el Runbook Oficial de Restauración y Prueba de Integridad.

3.1. Por qué la Restauración NO se incluye en la Aplicación Web

- **Aislamiento de Conexiones:** La restauración requiere la desconexión inmediata de todas las sesiones de usuarios (`SET SINGLE_USER WITH ROLLBACK IMMEDIATE`). Si se dispara desde el backend, la conexión que atiende la petición HTTP muere antes de completar el comando.
- **Integridad de Transacciones en Vuelo:** Una restauración accidental destruye inmediatamente ventas, pagos y movimientos que se estén procesando concurrentemente en los puntos de venta (POS).
- **Cumplimiento Normativo (Segregación de Funciones):** La norma ISO 27001 exige que la destrucción o sobreescritura de repositorios transaccionales requiera autenticación física o de red a nivel de infraestructura por parte del DBA.

3.2. Runbook Oficial de Restauración en Servidor (SSMS / sqlcmd)

El administrador dispone del procedimiento estándar documentado en `sql/03_administracion_mantenimiento/Mantenimiento_Backups.sql` :

```
-- PROCEDIMIENTO OFICIAL DE RESTAURACIÓN ANTE DESASTRE (DRP)
USE master;
GO

-- 1. Cerrar conexiones activas y poner la base en modo monousuario
ALTER DATABASE MUNDO_ESCOLAR SET SINGLE_USER WITH ROLLBACK IMMEDIATE;
GO

-- 2. Restaurar el último respaldo COMPLETO con NORECOVERY si se aplicarán diferenciales
RESTORE DATABASE MUNDO_ESCOLAR
FROM DISK = 'C:\SQLBackup\MUNDO_ESCOLAR_FULL_20261031_143000.bak'
WITH REPLACE, RECOVERY; -- Cambiar a NORECOVERY si se encadenará con DIFF
GO

-- 3. Devolver la base de datos a operación multiusuario normal
ALTER DATABASE MUNDO_ESCOLAR SET MULTI_USER;
GO
```

3.3. Script Automatizado para Pruebas de Restauración en Base Alterna

Para satisfacer la observación de Samir sobre comprobar que el respaldo es funcional sin destruir la base de datos de producción, se implementa el procedimiento de prueba en clon temporal (`MUNDO_ESCOLAR_DRP_TEST`):

```
-- PRUEBA DE RECUPERACIÓN EN BASE ALTERNA (NO DESTRUCTIVA)
USE master;
GO

-- 1. Restaurar en una base de datos secundaria temporal
RESTORE DATABASE MUNDO_ESCOLAR_DRP_TEST
FROM DISK = 'C:\SQLBackup\MUNDO_ESCOLAR_FULL_20261031_143000.bak'
WITH MOVE 'MUNDO_ESCOLAR' TO 'C:\SQLData\MUNDO_ESCOLAR_Test.mdf',
     MOVE 'MUNDO_ESCOLAR_log' TO 'C:\SQLData\MUNDO_ESCOLAR_Test_log.ldf',
     REPLACE;
GO

-- 2. Ejecutar validación de consistencia lógica
DBCC CHECKDB ('MUNDO_ESCOLAR_DRP_TEST') WITH NO_INFOMSGS;
GO

-- 3. Limpieza de base de prueba tras certificar éxito
DROP DATABASE MUNDO_ESCOLAR_DRP_TEST;
PRINT 'Certificación DRP completada: El respaldo es 100% íntegro y restaurable.';
GO
```

4. Estrategia de Automatización Portable (Express, Developer y Enterprise)

Dado que **SQL Server Express Edition no incluye el servicio SQL Server Agent**, se provee una arquitectura híbrida que garantiza la ejecución automática periódica sin importar la edición instalada.

4.1. Opción 1: Automatización Universal vía Programador de Tareas de Windows (Task Scheduler)

Esta opción funciona en el 100% de las ediciones (Express, Web, Standard, Developer y Enterprise) mediante un script `.bat` o `.ps1` que se ejecuta automáticamente en las horas de menor actividad:

FRECUENCIA	HORARIO SUGERIDO	COMANDO EJECUTADO POR TASK SCHEDULER	TIPO DE COPIA
Semanal	Domingos 01:00 AM	`sqlcmd -S localhost -d MUNDO_ESCOLAR -Q "EXEC SP_DBA_EjecutarBackupCompleto"`	Respaldo Completo (.bak)
Diaria	Lunes a Sábado 01:00 AM	`sqlcmd -S localhost -d MUNDO_ESCOLAR -Q "EXEC SP_DBA_EjecutarBackupDiferencial"`	Respaldo Diferencial (.bak)
Periódica	Cada 4 horas (si FULL)	`sqlcmd -S localhost -d MUNDO_ESCOLAR -Q "EXEC SP_DBA_EjecutarBackupLog"`	Respaldo de Log (.trn)

4.2. Opción 2: Script de Creación de Jobs para SQL Server Agent (Ediciones con Agent)

Para servidores que cuenten con SQL Server Agent (Developer o Enterprise), se provee el script modular `sql/03_administracion_mantenimiento/Crear_Jobs_Agent.sql`:

```
-- sql/03_administracion_mantenimiento/Crear_Jobs_Agent.sql (Opcional para ediciones con Agent)
USE msdb;
GO

IF EXISTS (SELECT 1 FROM sys.configurations WHERE name = 'Agent XPs' AND value_in_use = 1)
BEGIN
    -- 1. Crear Job de Respaldo Completo Semanal
    EXEC sp_add_job @job_name = N'MundoEscolar_Backup_Semanal', @enabled = 1, @description = N'Respaldo completo de MUNDO_ESCOLA
R';
    EXEC sp_add_jobstep @job_name = N'MundoEscolar_Backup_Semanal', @step_name = N'Ejecutar SP Backup Completo',
        @subsystem = N'TSQL', @command = N'EXEC MUNDO_ESCOLAR.dbo.SP_DBA_EjecutarBackupCompleto;', @database_name = N'MUNDO_ESCOL
AR';
    EXEC sp_add_jobschedule @job_name = N'MundoEscolar_Backup_Semanal', @name = N'Horario_Domingo_01AM',
        @freq_type = 8, @freq_interval = 1, @active_start_time = 010000;
    EXEC sp_add_jobserver @job_name = N'MundoEscolar_Backup_Semanal', @server_name = N'(LOCAL)';
    PRINT 'Job de SQL Server Agent creado exitosamente.';
END
ELSE
BEGIN
    PRINT 'SQL Server Agent no está disponible en esta edición. Utilice Windows Task Scheduler.';
END;
GO
```

4.3. Opción 3: Tarea Programada Interna en Backend NestJS (@nestjs/schedule)

Como valor agregado en la capa de aplicación, el backend NestJS puede incorporar un servicio de cron con `@Cron(CronExpression.EVERY_WEEK)` que invoque internamente al servicio `DbaService.ejecutarBackupCompleto()`, asegurando que si la aplicación está encendida en un servidor Node.js, los respaldos se generen sin dependencias del sistema operativo anfitrión.

5. Implementación Práctica de la Regla 3-2-1 (Copia Off-Site)

Para dar cumplimiento formal al principio de contingencia y resiliencia de datos, se incorpora un script de post-procesamiento que extrae los archivos `.bak` y los sincroniza fuera del servidor local:

PILAR DE LA REGLA 3-2-1	IMPLEMENTACIÓN TÉCNICA EN MUNDO ESCOLAR	HERRAMIENTA / MECANISMO
3 Copias de los Datos	Base de datos activa en producción + Copia local en `C:SQLBackup` + Copia externa off-site.	Procedimientos T-SQL nativos + Script de replicación.
2 Medios Distintos	Medio 1: Disco local del servidor (NVMe/SSD). Medio 2: Unidad de red (NAS) o Cloud Object Storage.	Almacenamiento físico desacoplado.
1 Copia Fuera de Sitio	Sincronización automática de archivos `.bak` hacia Azure Blob Storage / AWS S3 / OneDrive corporativo.	PowerShell con `AzCopy` o CLI de nube.

```
# Script de Replicacion Fuera de Sitio (PowerShell Post-Backup)
$sourcePath = "C:\SQLBackup"
$destinationNAS = "\\NAS-MundoEscolar\Respaldos" # O bucket en la nube

# Sincronizar archivos .bak creados en las últimas 24 horas y depurar archivos mayores a 30 días
Get-ChildItem -Path $sourcePath -Filter "*.bak" | Where-Object { $_.LastWriteTime -gt (Get-Date).AddDays(-1) } | ForEach-Object {
    Copy-Item $_.FullName -Destination $destinationNAS -Force
    Write-Host "Archivo respaldado externamente: $($_.Name)" -ForegroundColor Green
}
```

---

6. Matriz de Acciones de Implementación Inmediata

El siguiente plan de acción resume los cambios que el equipo aplicará en el proyecto para cerrar al 100% este tema:

#	COMPONENTE AFECTADO	ACCIÓN TÉCNICA CONCRETA	RESPONSABLE	IMPACTO
1	`10_CrearProcedimientos.sql`	Añadir `WITH EXECUTE AS OWNER` a los 4 SPs de respaldo (SPs 69 al 72).	Mauricio Ch.	Elimina el fallo de permisos sin exponer contraseñas ni usar `sa`.
2	`Seguridad.sql`	Añadir `ALTER ROLE db_backupoperator ADD MEMBER usr_mundo_app;` como respaldo de compatibilidad.	Mauricio Ch.	Asegura autorización nativa directa si se ejecutan herramientas externas.
3	`sql/03_administracion.../`	Crear el script `Preparar_Carpeta_Respaldos.ps1` con ACLs automáticas.	Equipo DBA	Previene errores de permisos en disco (OS Error 5).
4	Documentación / Defensa	Justificar ante el profesor la exclusión del botón de restauración como una decisión de seguridad DRP.	Equipo Completo	Posiciona al equipo con altos estándares de ciberseguridad.

> **CONCLUSIÓN DE LA PROPUESTA**
>
> Con esta propuesta, no sólo respondemos con elegancia y solvencia técnica a las observaciones de Samir, sino que elevamos la solución a estándares profesionales de nivel bancario y corporativo, demostrando dominio de seguridad de base de datos, administración de sistemas y gobernanza de TI.

Mauricio Chavarría Pérez
Liderazgo Técnico y Arquitectura
Mundo Escolar S.A.

Equipo de Desarrollo y Aseguramiento
Revisión y Aprobación de Arquitectura
Universidad Nacional